Who is responsible for cyber security in the enterprise?

Nick Ismail

Different organisations place the responsibility of cyber security at the feet of different roles. This depends on the type of organisation, its culture and size.

This idea is confirmed by a Global Economist Intelligence Unit survey, sponsored by Willis Towers Watson, which found that there is a variety of approaches on how leadership implements cyber resiliency across their organisations.

Stronger communication and collaboration is needed across all various cyber security functions and practices, including between the board and the CTO or CISO.

The cyber security responsibility

With the increase of more stringent data regulations – like GDPR and California Consumer Privacy Act – and the widespread media coverage of data breaches, the impetus on cyber security has never been so high. Poor security practice will now inevitably lead to a breach, which will in turn cause financial loss and reputational damage. Corporate heads will also roll.

>Read more on Cyber security best practice

The problem is that the majority of executives around the world feel they face a "specialist-generalist" dilemma as to whom leads on cyber resiliency, according to the survey from Willis Towers Watson. This is because, the challenge of security is company-wide, but whoever is in charge of it needs specific, up-to-date cyber training. Are these business-focused, cyber-savvy, "specialist-generalist" individuals in short supply?

Ultimately, there is a huge disparity across organisations as to who should be responsible for cyber security. The survey of over 450 companies found that almost 40% of executives felt that the board should oversee cyber, compared with 24% who felt it should be the role of a specialised cyber committee. This would presumably be overseen by the CTO or CISO. A small portion of respondents surveyed believed it should be the responsibility of audit, risk or some other subgroup.

"When you dig into the details of a breach you will find warnings from the information security team well before the problem is finally exposed," said Stephen Moore, Chief Security Strategist at Exabeam. "Most of these warnings are ignored. The real question is why is that?"

"It's often said that security is everyone's responsibility and academically the CISO has the authority, both are lies. Organisationally, we should worry less about responsibility and more about barriers to success. The responsible owner is the person or team who can best enact the qualified recommendations of the security team. Often the threat isn't the adversary, it's the lack of internal support, warnings being buried, and even the fear of outages that creates the conditions for failure."

>Read more on Cyber security training

“Recommendations should be tied observable failures to prevent, detect, or disrupt attacks – not things like workbook-based audit findings. The ownership and delivery of cyber security in an organisation must be owned outside of the IT department.”

Tim Brown, VP of Security at SolarWinds MSP, agreed and said that cyber security isn’t the responsibility of one department. Security needs to be built into how a business operates.

“From finance, to HR, to marketing, to operations – everyone needs to be a good cyber steward. It’s really all hands on deck to make sure the entire organisation is adhering to the right protocols, practicing good cyberhygiene, and understanding how their specific job plays into the cyber landscape.”

Cyber security challenge

The main challenge, hindering the decision of who is responsible for cyber security, is a lack of communication within leadership roles.

Alarmingly, or perhaps unfairly, only 8% of executives said that their CISO or equivalent performs above average in communicating the financial, workforce, reputational or personal consequences of cyber threats. At the same time, under 15% go executives gave their CISOs or equivalent a top rating from a scale of one to ten.

>Read more on Cyber security – the unrelenting challenge for readership

“It is no surprise that one of the main challenges companies face when implementing a cyber risk mitigation or resiliency plan is the communication gap between the board and the CISO,” said Anthony Dagostino, global head of cyber risk with Willis Towers Watson.

“Cyber resiliency starts with the board because they understand risk and can help their organizations set the appropriate strategy to effectively mitigate that risk. However, while CISOs are security specialists, most of them still struggle with adequately translating security threats into operational and financial impact to their organisations – which is what boards want to understand.”

“To close this communication gap, CISOs [or CTOs] need tools that can help them quantify and translate the vulnerabilities uncovered from their cybersecurity maturity assessments. These tools enable them to better communicate the risk to the board, seek adequate budget, and enable the board to provide meaningful guidance.”

Cyber security budget

Enterprise security budgets depend on the size of the organisation and the type of industry they are a part of. In general, funds dedicated to security move between 3% and 15% of an IT budget.

“With enterprises, the budget is often shared across many different departments and the budget can be fairly significant depending on their specific needs,” said Brown.

>Read more on Worldwide enterprise security spending

“With affordable and scalable outsourcing options available through today’s managed service providers, security certainly doesn’t have to break the bank to be effective and even smaller businesses can ensure they’re doing these types of basics. Couple that with the idea that security should be viewed as a ubiquitous function of the organisation, and you’ve got a great foundation.”

https://www.youtube.com/watch?v=bZbYbdcXRIo

“The budget allocation depends on your companies appetite for risk – most companies will be aware of attacks on their business, many will have put estimates of the financial cost to loss of business and reputational damage it can cause,” according to Terry Storrar, Sales Director, End User Sales at MCSA Group.

“Over the last few days British Airways revealed details of a breech and that they are prepared to repay any financial losses incurred by their customers, the cost in financial terms is often dwarfed by the ongoing damage to the company’s reputation. Companies need to have the right level of systems security for their business, a detailed and practiced business recovery plan and a process that kicks into action so that in the event of an attack their business continuity strategy is implemented and minimises the risks to their customers and to their business.”

More budget: Better security?

More budget doesn’t mean better security, according to Moore. “Money alone won’t save a company; the organisational co-operation must match budget, otherwise security maturity and efficacy will not change.”

“If placed within the IT organisation, information security will operate in a conflict of interests. Security requires reactive corrections to flawed environments. Corrections always come at an operational cost, often in the form of an outage. IT works on performance and availability, and cares little for security – especially if it erodes their two favourite metrics – often tied to their bonus dollars.”